

Business logic vulnerabilities

Lab: Insufficient workflow validation

Cilj zadatka: iskoristiti logički propust u procesu kupovine kako bi se besplatno kupio skupoceni proizvod "Lightweight l33t leather jacket". Ranjivost: Nedovoljna validacija radnog toka (Workflow Validation). Aplikacija pretpostavlja da korisnik može doći do stranice za potvrdu porudžbine (/cart/order-confirmation) isključivo nakon što uspešno prođe kroz naplatu (POST /cart/checkout). Međutim, backend ne proverava da li je naplata zaista izvršena i skinut novac, već samo prisustvo artikala u korpi u trenutku učitavanja potvrde.

Postupak rešavanja:

1. Ulogovati se na aplikaciju sa odgovarajućim kredencijalima
2. Kupiti neki proizvod koji može da se priušti trenutnim sredstvima na kartici



Insufficient workflow validation

Back to lab description >>

LAB

Not solved



Store credit:
\$93.78

Home | [My account](#) |  0

Your order is on its way!

Name	Price	Quantity
ZZZZZ Bed - Your New Home Office	\$6.22	1

Total: \$6.22

3. Pregledati proxy istoriju i uočiti da zahtev POST /cart/checkout preusmerava na stranicu za potvrdu porudžbine
4. Poslati GET /cart/order-confirmation?order-confirmation=true u Burp Repeater

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Discover

Intercept HTTP history WebSockets history Match and replace Proxy settings

Filter settings: Hiding CSS and image content; hiding specific extensions Pro version only

#	Host	Method	URL	Params	Edited	Status code	Length	MIME type	Extension	Title	Notes	TLS	IP	Cookies	Time	Listener port	Start resp
4917	https://phishingstaging.port...	POST	/v0/e/tp=08...=17809753807588v...		✓	200	308	JSON				✓	54.77.23.236	05:23:08 9 J...	8080	145	
4916	https://phishingstaging.port...	POST	/v0/e/tp=08...=17809753837748v...		✓	200	308	JSON				✓	54.77.23.236	05:23:03 9 J...	8080	158	
4915	https://0a3f00fd042b453c838...	GET	/academyLabHeader			101	147					✓	34.246.129.62	05:22:35 9 J...	8080	89	
4914	https://0a3f00fd042b453c838...	GET	/cart/order-conformation?order-con...		✓	200	4220	HTML		Insufficient workflow v...		✓	34.246.129.62	05:22:35 9 J...	8080	83	
4913	https://0a3f00fd042b453c838...	POST	/cart/checkout		✓	303	129					✓	34.246.129.62	05:22:34 9 J...	8080	81	
4912	https://www.youtube.com	POST	/youtube/v1/log_event?alt=json		✓	200	370	JSON				✓	142.250.203.142	05:22:32 9 J...	8080	81	
4911	https://www.youtube.com	POST	/youtube/v1/log_event?alt=json		✓	200	370	JSON				✓	142.250.203.142	05:22:32 9 J...	8080	81	
4910	https://0a3f00fd042b453c838...	GET	/academyLabHeader			101	147					✓	34.246.129.62	05:22:13 9 J...	8080	134	
4909	https://0a3f00fd042b453c838...	GET	/cart			200	6504	HTML		Insufficient workflow v...		✓	34.246.129.62	05:22:13 9 J...	8080	78	
4908	https://0a3f00fd042b453c838...	GET	/academyLabHeader			101	147					✓	34.246.129.62	05:22:11 9 J...	8080	77	
4917	https://0a3f00fd042b453c838...	POST	/search?utf8=&search=3		✓	200	12177	HTML		Insufficient workflow v...		✓	34.246.129.62	05:22:11 9 J...	8080	72	

Request

Pretty Raw Hex

```

1 GET /cart/order-conformation?order-con= HTTP/1.1
2 Host: 0a3f00fd042b453c8380300b904007300ed.web-security-academy.net
3 Cookie: session=7u70040dfq0IU0V14QSi400V99xt0Ba?
4 Cache-Control: max-age=0
5 Accept-Language: en-US,en;q=0.5
6 Upgrade-Insecure-Requests: 1
7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.26 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.26
8 Accept:
9 text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
10 Sec-Fetch-Site: same-origin
11 Sec-Fetch-Mode: navigate
12 Sec-Fetch-User: ?1
13 Sec-Fetch-Dest: document
14 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
15 Sec-Ch-Ua-Mobile: ?0
16 Sec-Ch-Ua-Platform: "Windows"
17 Referer: https://0a3f00fd042b453c8380300b904007300ed.web-security-academy.net/cart

```

Response

Pretty Raw Hex Render

```

1 HTTP/1.1 200 OK
2 Content-Type: text/html; charset=utf-8
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 4112
5
6 <!DOCTYPE html>
7 <html>
8 <!--LAB_HEADER_START-->
9 <head>
10 <link href=/resources/labheader/css/academyLabHeader.css rel=stylesheet>
11 <link href=/resources/css/labs.css rel=stylesheet>
12 <title>
13 Insufficient workflow validation
14 </title>
15 <!--LAB_HEADER_END-->
16 <body>
17 <script src=/resources/labheader/js/labHeader.js>
18 </script>
19 <!--LAB_HEADER_START-->

```

Inspector

Request attributes 2

Request query parameters 1

Request cookies 1

Request headers 20

Response headers 3

5. Dodati jaknu u korpu

Insufficient workflow validation

LAB Not solved

Back to lab description >>

Store credit:

\$93.78

Cart

Name	Price	Quantity
Lightweight "I33t" Leather Jacket	\$1337.00	- 1 + Remove

Coupon:

Add coupon

Apply

6. Kroz Burp Repeater ponovo poslati zahtev za potvrdu

7. Porudžbina se uspešno završava bez oduzimanja novca sa kartice, čime se zadatak završava



Congratulations, you solved the lab!

Share your skills!



[Continue learning >>](#)

Store credit:
\$93.78

[Home](#) | [My account](#) | 1

Cart

Name	Price	Quantity		
Lightweight "I33t" Leather Jacket	\$1337.00	-	1	+ Remove

Coupon:

Add coupon

Apply